

Living Off The Land – Theory Brief

Living Off The Land Theory – Three-Gate Brief

Fidelity level: 30% (Concept)
[A]+[?] percentage: 62% (calculated from 34 tagged claims: 13 [R], 18 [A], 3 [?])
Gate verdict: At 30% fidelity, this ratio is acceptable. The industry problem is real [R]; whether it's Adlumin's customer problem is [?]. Proceed to Q3 workshops (PUT-1153) for validation before committing build resources.

Gate 1 – Problem: Is LOTL a real, sourced customer problem?

Industry-level problem: Yes [R]

- 84% of high-severity attacks in 2025 use LOTL techniques [R] – CybersecurityHQ Report 2025 (cited in ROI strategy; not independently verified)
- CrowdStrike reports 62% of detections involve LOTL [R] – CrowdStrike Threat Report 2025 (cited)
- LOTL attacks use legitimate tools (cmd.exe, powershell.exe, wmic, rundll32, etc.) [R] – Kevin O'Connor's technical doc lists 20+ Windows binaries, sourced from LOLBAS project
- Attackers use valid credentials and move slowly [R] – ROI strategy framing, aligned with CISA/NSA/FBI Volt Typhoon guidance (cited)
- Traditional signature-based detection cannot identify LOTL [R] – behavior looks normal; stated across all three sources

Adlumin-specific technical capability: Yes [D]

- PowerShell ensemble model analyzes ~1B commands/week [D] – cited in ADL-1381 (ROI strategy)
- Endpoint detection expansion in progress (ADL-1381) [R]
- Tamper-proof research underway (ADL-1294) [R]

Customer-level problem: Unknown [?]

- No validated personas yet [?] – planned Q3 via PUT-1152
- Chorus call analysis "just starting" [?] – transcripts flowing into Condens, not producing signal yet
- No Jobs-to-Be-Done or workflow ethnography [?]
- Competitive analysis last updated January 2024 [R] – outdated; market has shifted
- One SME interview [R], one partner interview planned [?], one customer journey map from Nov 2024 [R] – not statistically meaningful

The gap [A]:

We assume customers care about LOTL because competitors market it. But we have no evidence that:

- Customers ask about LOTL in sales calls [?]
- LOTL coverage influences purchase decisions [?]
- Naming LOTL detection improves renewal rates [?]

Strategic risk [A]:

If LOTL is an *industry talking point* but not a *customer decision factor*, naming it clutters positioning without ROI. Alternatively, if customers *do* care and Adlumin stays silent, we appear behind even when the tech exists [A].

Why AI is required for LOTL [R]:

- Humans and static rules look for known-bad signatures [R]
- LOTL hides inside normal patterns [R]
- AI must learn "normal" at scale, detect drift, correlate behavior over time [A] – concept stated; implementation clarity [?]

Detection complexity [R]:

From EDR evasion doc (Brendan Griffin):

- Process/service kill: Medium detection complexity [R]
- BYOVD (Bring Your Own Vulnerable Driver): Medium to High detection complexity [R]
- Traffic blocking (EDRSilencer, hosts file): High detection complexity [R]
- Anti-rootkit tool abuse: Low detection complexity [R]

Adlumin's current detection posture against these vectors: [?] – not mapped.

Gate 2 – Right Thing: Does naming LOTL advance Adlumin's mission?

Mission (inferred from ROI strategy) [A]:

Position Adlumin as AI-led security platform, not feature-led. Differentiate on outcomes (risk reduced, time saved) vs. telemetry breadth [A].

How LOTL naming could advance mission [A]:

- **Market alignment** [R] – LOTL is the dominant 2026 attack style; competitors (CrowdStrike, Palo Alto, SentinelOne) name it explicitly [R] – cited in ROI strategy
- **AI justification** [A] – LOTL is the clearest use case for why AI is *required*, not optional. Naming it makes the AI narrative concrete [A]
- **Differentiation from feature-led competitors** [A] – Arctic Wolf and ConnectWise are manual-heavy [R]; Adlumin's automated detection is a structural advantage if named [A]

Counter-narrative [A]:

- If customers don't ask for LOTL coverage, naming it is premature [A]
- If detection generates high false positives, naming it becomes a liability [A]
- Adlumin's PowerShell model is unnamed but functional; naming might overpromise before tuning is complete [A]

What outcome moves if we name LOTL [?]:

- Sales cycle velocity? [?]
- Win rate in competitive evals? [?]
- Renewal rate? [?]
- Expansion ARR? [?]

None of these are measured yet. Q3 personas (PUT-1152) and Q4 workshops (PUT-1153) are the validation gates [R].

Strategic positioning verdict [A]:

Naming LOTL positions Adlumin correctly *to the market*. Whether it positions Adlumin correctly *to customers* is unknown [?].

Gate 3 – Built Right: What would validate this concept?

At 30% fidelity (Concept tier), Gate 3 is thin by design [A].

Success criteria (concept validation) [A]:

- **Customer language test** [A] – Do customers use the term "living off the land" or describe the problem without naming it? Validate via Chorus analysis (PUT-1109) [A]
- **Competitive benchmark** [A] – Do lost deals cite LOTL coverage gaps? Requires updated competitive analysis (Jan 2024 → 2026) [A]
- **Workshop validation** [A] – Q4 2026 workshops (PUT-1153) test LOTL visibility concepts. Success = 3+ customers name LOTL coverage as differentiator in competitive eval [A]

What "built right" would look like at higher fidelity [A]:

- **60% (Direction):** LOTL detection scorecard showing false positive rate, coverage by MITRE ATT&CK technique, MTTR [A]
- **90% (Spec-ready):** Named LOTL dashboard, explainability layer (why this command sequence is suspicious), override mechanism [A]

Detection performance baseline (missing) [?]:

- Current false positive rate for PowerShell ensemble model: [?]
- Coverage map: which LOTL techniques does Adlumin detect vs. miss? [?]
- MTTR for LOTL-style attacks: [?]

Without this, "built right" cannot be evaluated [A].

Counter-metric (what must not get worse) [A]:

- **Alert fatigue** [A] – If LOTL detection is noisy, customers will disable it or ignore it. CrowdStrike's Charlotte AI claims ~85% analyst workload reduction [R]; Adlumin's RACE has no published baseline [?]
- **Trust erosion** [A] – If AI explanations are opaque, analysts will override or bypass the system [A]

Failure Modes

- **LOTL is an industry buzzword, not a customer buying criterion** [A]

Beth names LOTL; customers shrug; sales cycle unchanged. Mitigation: Validate via Chorus + workshops before committing marketing budget [A].

- **Detection is functional but noisy** [A]

PowerShell model generates high false positives; SOC teams tune it down or disable it; naming LOTL as a capability becomes a liability. Mitigation: Publish detection performance baseline before marketing [A].

What's Missing

Honest list of unknowns:

- [] Do Adlumin customers ask about LOTL in sales calls? [?]
- [] Does LOTL coverage appear in lost-deal autopsies? [?]
- [] What is the false positive rate for PowerShell ensemble model? [?]
- [] Which LOTL techniques does Adlumin detect vs. miss? (MITRE ATT&CK T1059, T1218, T1003, etc.) [?]
- [] What is MTTR for LOTL-style attacks in Adlumin's telemetry? [?]
- [] How do customers describe the problem without using "LOTL"? [?]
- [] What would make a customer choose Adlumin *because* of LOTL coverage? [?]
- [] What ROI claim can Adlumin make? (incidents avoided, time saved, risk reduced) [?]

Validation path [A]:

- Q2 2026: Chorus synthesis with LOTL-specific questions (PUT-1109) [R]
- Q3 2026: Validated personas including threat-landscape segmentation (PUT-1152) [R]
- Q3 2026: Detection coverage audit (MITRE ATT&CK mapping) [A]
- Q4 2026: Workshops testing LOTL visibility concepts (PUT-1153) [R]

Theory status [A]:

Beth's "living off the land theory" is strategically sound [A]. The industry problem is real [R]. Adlumin's technical capability exists [D]. The customer problem is assumed [?]. Proceed to validation; do not commit build resources until workshops (PUT-1153) confirm customer language and decision criteria [A].